Shai-Hulud

Un ver géant dans mon node_modules !



Arthur MURILLO

08/11/2026



Développeur

Speaker

Expert en sieste tactique


Angular c'est dépassé, la bonne pratique c'est [*framework sorti hier*]



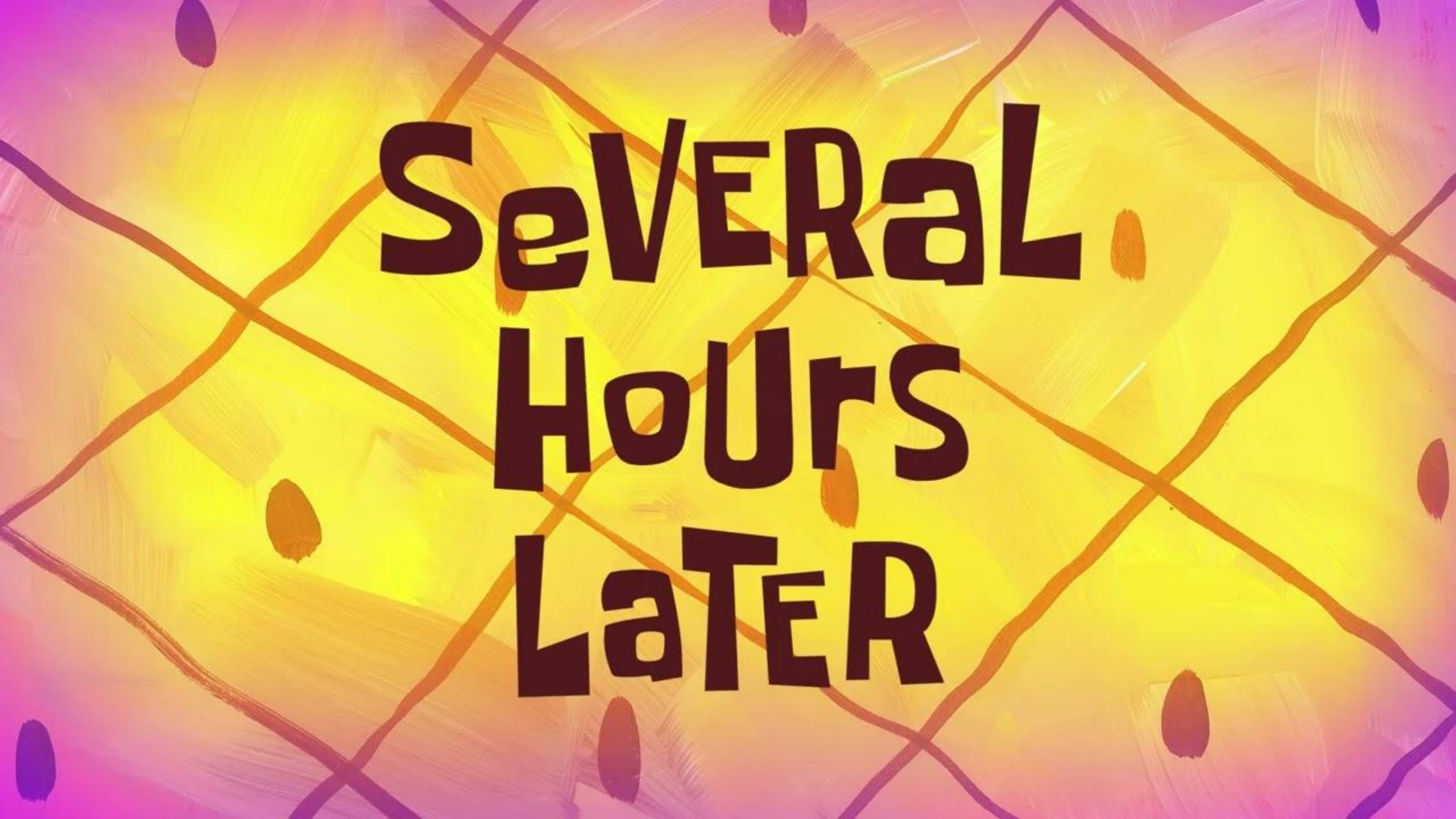

Microsoft®
Windows®xp
Copyright © Microsoft Corporation
Microsoft




> npm install




> 1 package installed.


SEVERAL
HOURS
LATER






wtf


N’utilise pas
« !important » dans ton
css, c’est mal

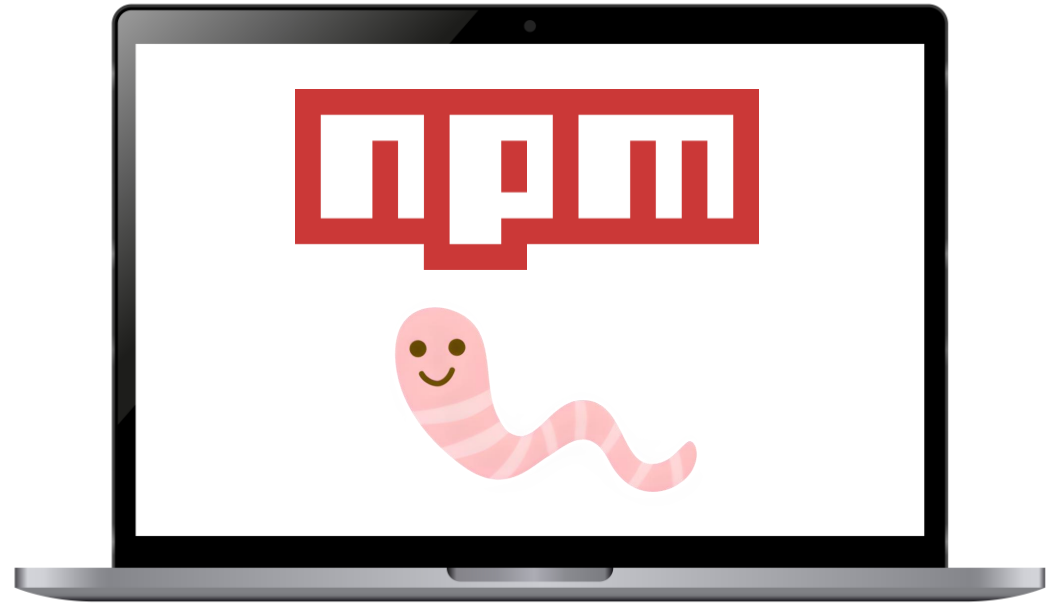



1




Reconnecté vous de
toute urgance svp !!!




سم




















Oups




UNIT 42™
BY PALO ALTO NETWORKS

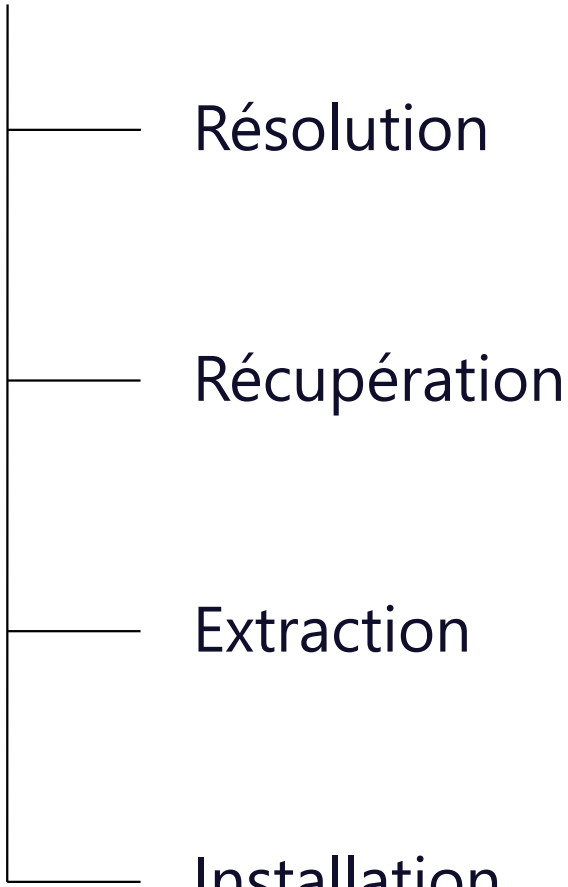


Supply chain

Utiliser les **dépendances** d'un projet comme vecteur **d'attaque**

npm **install**

`npm` **`install`**



`npm` **`install`**





- Résolution
- Récupération
- Extraction
- Installation

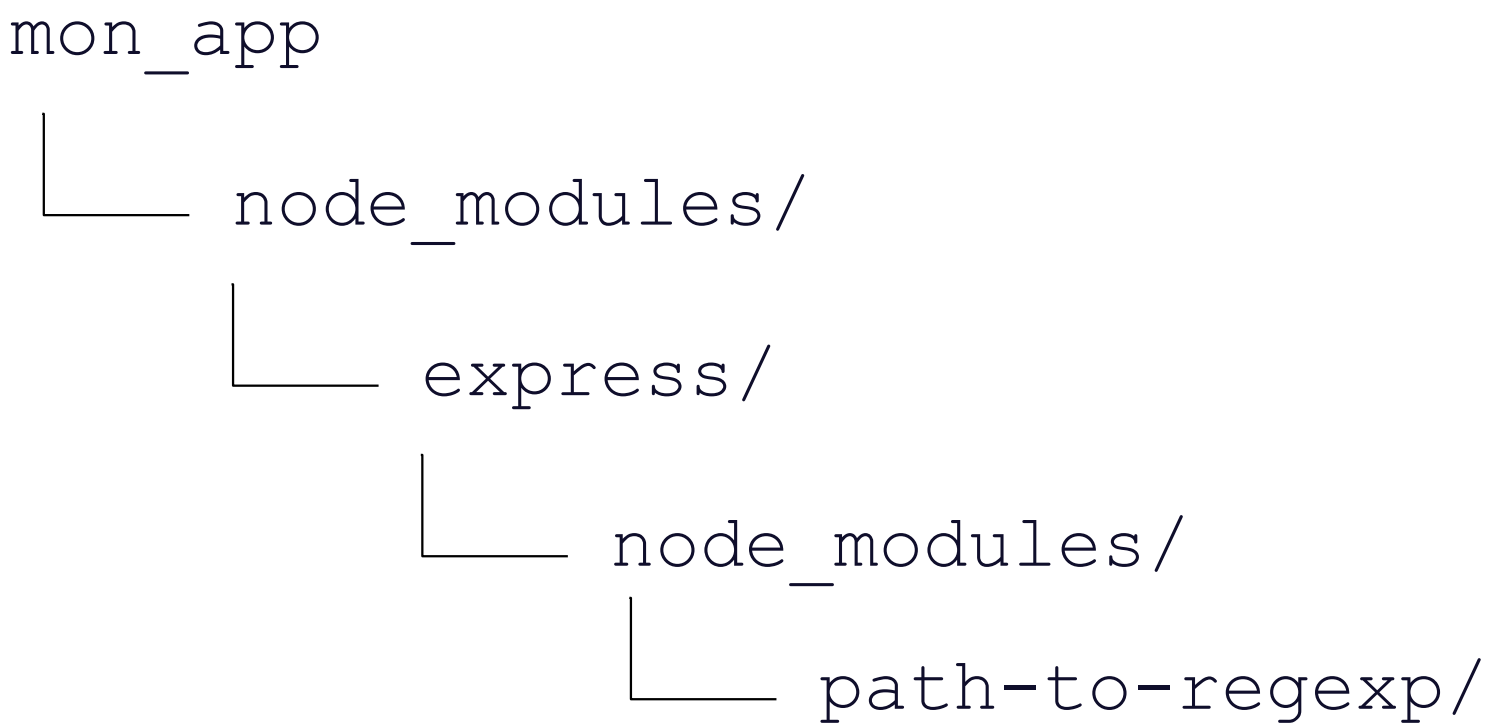
hoist ~ *verb [hɔɪst]*

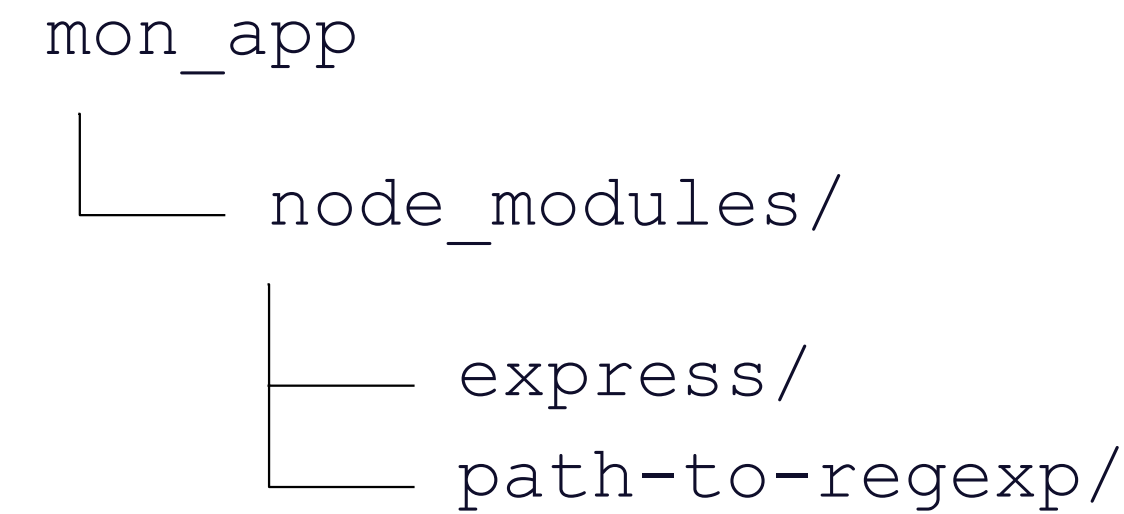
to lift something heavy, sometimes using ropes or a machine



path-to-regexp

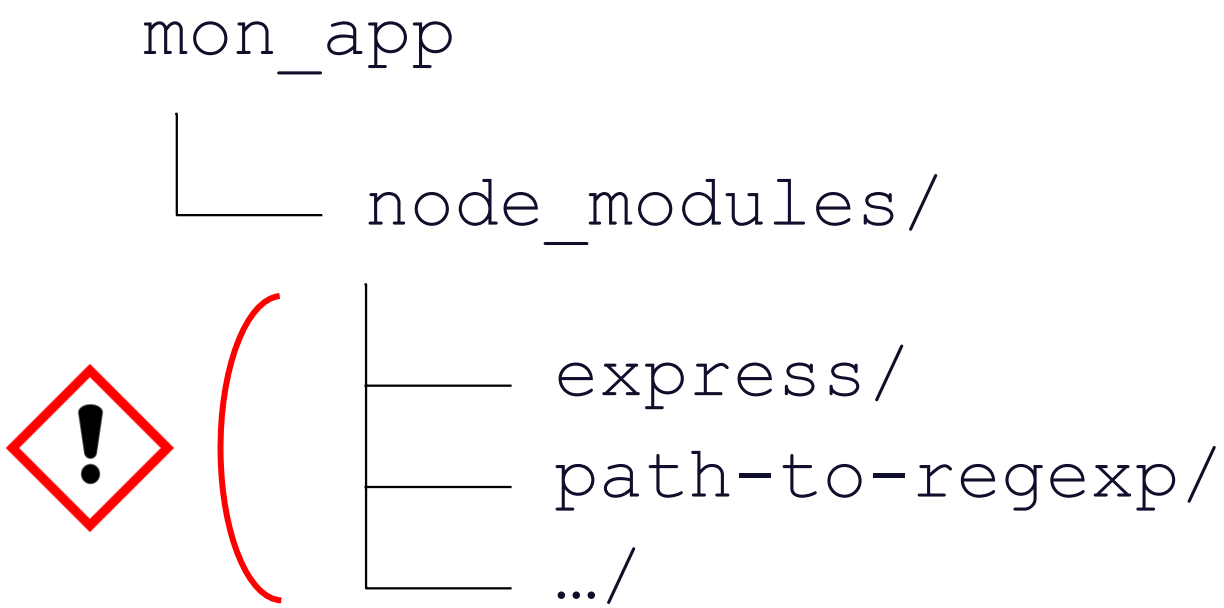
8.4.2 • Public


mon_app
node_modules/
express/
node_modules/
path-to-regexp/


mon_app
node_modules/
express/
path-to-regexp/

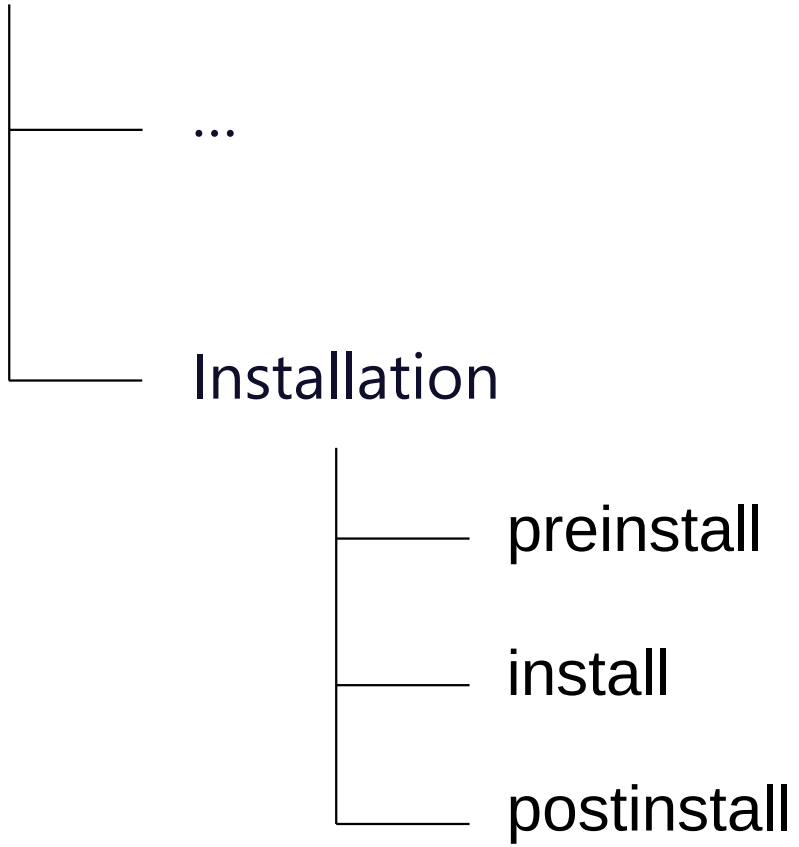
```
const regexp = require('path-to-regexp');
```




mon_app
node_modules/
express/
path-to-regexp/
…/

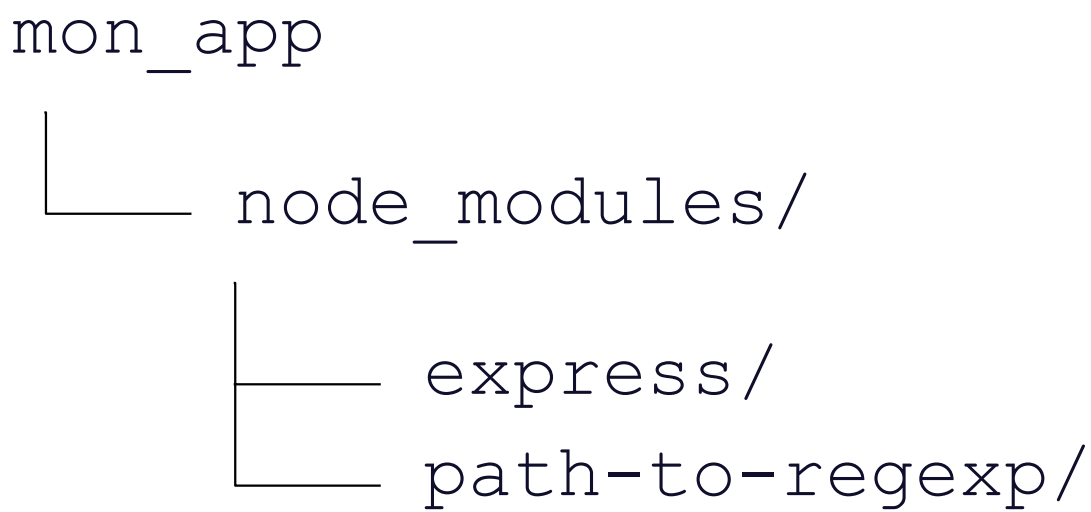

SWS

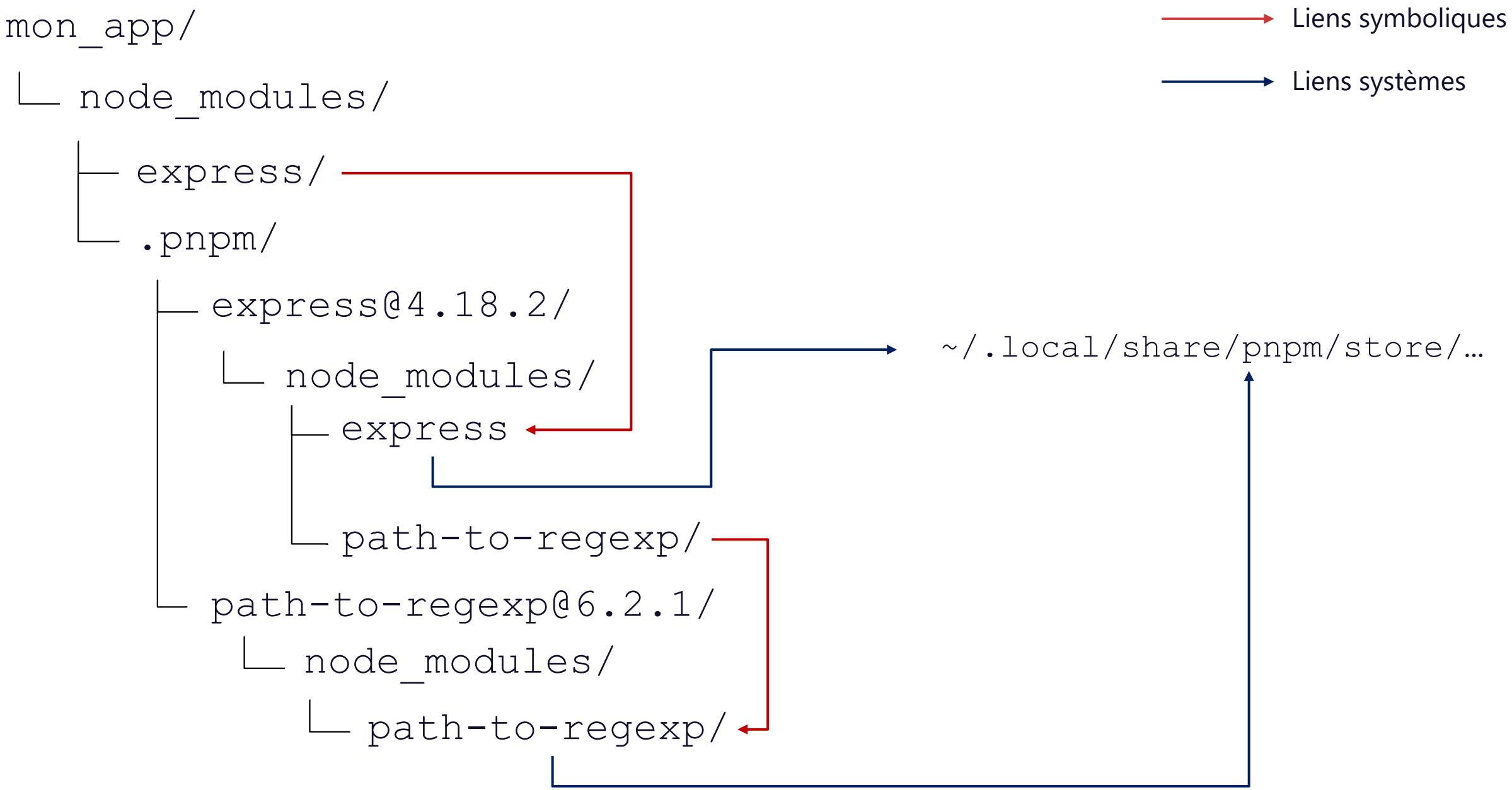
`npm` **`install`**

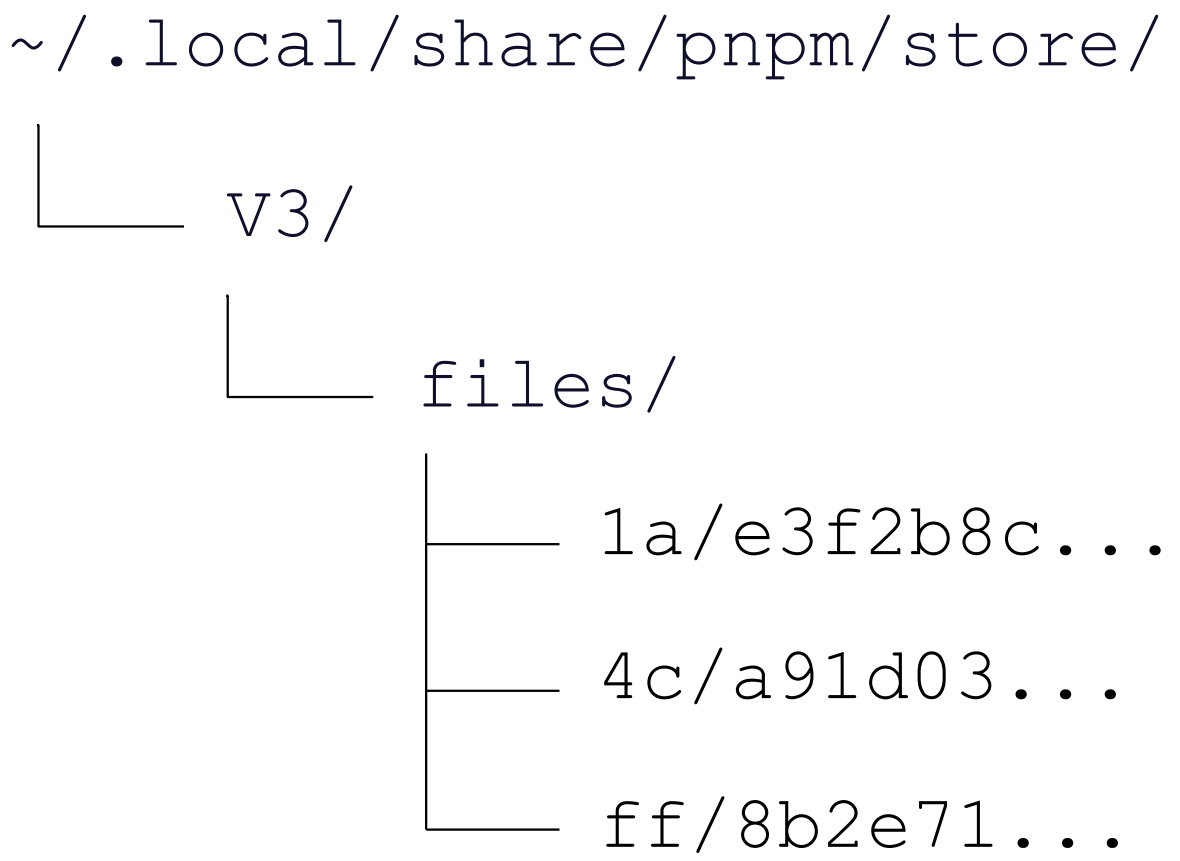


```
{
    "name": "path-to-regexp",
    "scripts": {
        "preinstall": "./scripts/pre.sh",
        "install": "node-gyp rebuild",
        "postinstall": "./scripts/post.sh"
    }
}
```


pnpm


mon_app
node_modules/
express/
path-to-regexp/


mon_app/
node_modules/
express/
.pnpm/
express@4.18.2/
node_modules/
express
path-to-regexp/
path-to-regexp@6.2.1/
node_modules/
path-to-regexp/
~/.local/share/pnpm/store/…
Liens symboliques
Liens systèmes


~/.local/share/pnpm/store/
v3/
files/
1a/e3f2b8c...
4c/a91d03...
ff/8b2e71...



```
mon_app/
└─ node_modules/
⚠  ( ├─ express/
     └─ .pnpm/
          ├─ express@4.18.2/
          │
          └─ path-to-regexp@6.2.1/
```







npm



pnpm

WARN - The following dependencies have scripts that were not run during installation:

esbuild (has a postinstall script that was ignored)

```
minimumReleaseAge: 1440
```

pnpm **install** *path-to-regexp*

ERR_PNPM_NO_MATURE_MATCHING_VERSION

Version *X.Y.Z* (released 10 minutes ago) of path-to-regexp **does not meet** the minimumReleaseAge constraint

pnpm **patch** *path-to-regexp*


Et ton machin pnpm, c’est compliqué de migrer dessus ?




Ouais mais c’était un petit exemple ca !



2 applications conséquentes **en prod**

1500 dépendances

750+ tests unitaires

1 jour ½ de migration sur pnpm

Recherche de documentation

Installation sur les projets

Rédaction d'un retour d'expérience

Adaptations suite au changement de structure du node_*modules*

Intégration dans le pipeline CI/CD

Déploiement sur l'infrastructure cible

Tests exploratoires

npm c'est dépassé, la bonne pratique maintenant c'est *pnpm*



Ouais mais et si tu utilises ....



Et si je n’ai **pas** envie d’utiliser une **alternative** ?


Quand tu attends que ta MR soit relue

npm **audit**

```
[+] no known vulnerabilities found
    Packages audited : …
```

```
audited 3090 packages in 21.506s
found 133 vulnerabilities (27 moderate, 74 high, 32 critical)
```

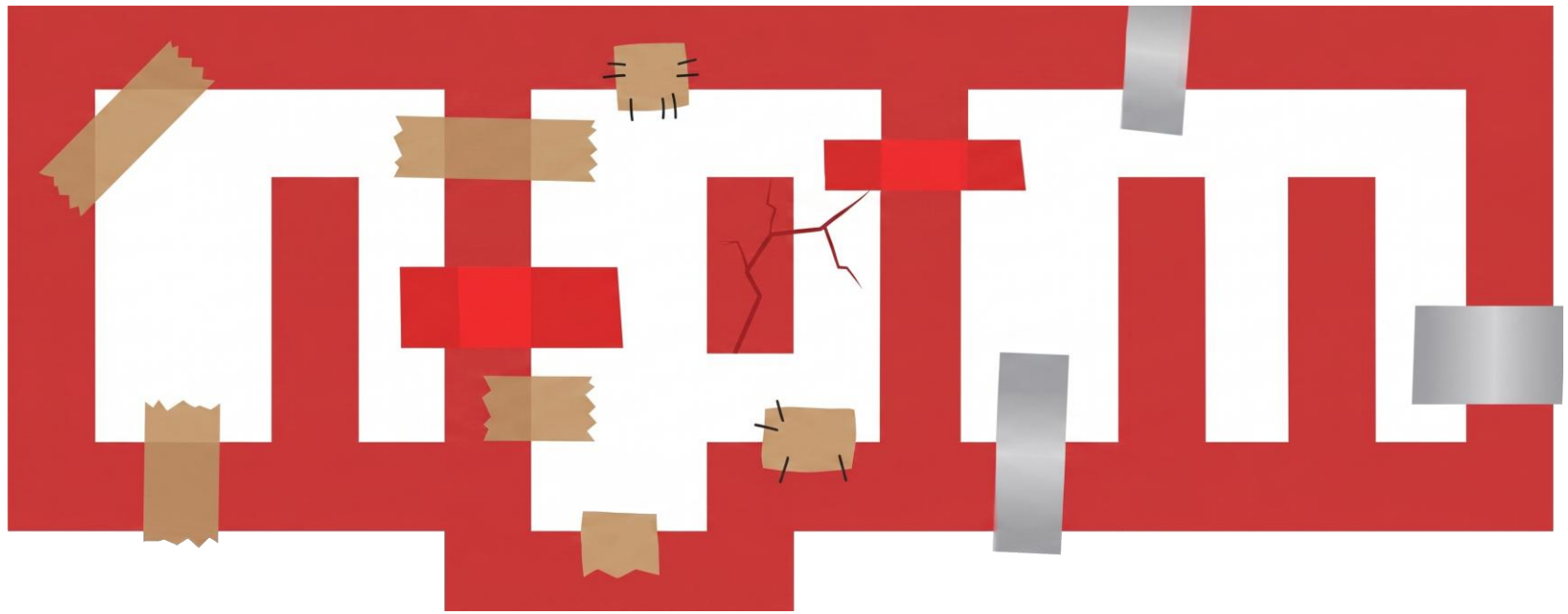
npm **ci**

NPM 11.10.0 adds `min-release-age`

May 21, 2026 · 1 min · Brandon Pugh | Suggest Changes

After Years of Supply Chain Attacks, npm Is Finally Closing the Door on Auto-Scripts

Jun 11, 2026 • MaK Ulac 4 - 7 min read



	npm	yarn (V1)	yarn (V2+)	pnpm
Scripts bloqués par défaut	✅ (v12+)	❌	❌	✅
Dépendances fantômes	✅	✅	✅ (Par défaut)	❌
Isolation des dépendances	❌	❌	❌ (Par défaut)	✅
Délai de maturité avant installation	✅ (v11.10+)	❌	✅ (v4.10+)	✅ (v10.16+)



Shift **left**




QUI VEUT GAGNER DES
VERS DE TERRE
QUI VEUT GAGNER DES



Qu'est ce qu'une attaque supply chain ?

A: une arnaque consistant à acheter pas cher en chine et à revendre plus cher en France

B: Compromettre un paquet ou un fournisseur pour atteindre un projet qui en dépend

C: l'attaque d'un bateau cargo pour augmenter les prix de l'essence

D: quand le livreur indique « remis en main propre » alors qu'il l'a juste gardé pour lui

Qu'est ce qu'une attaque supply chain ?

A: une arnaque consistant à acheter pas cher en chine et à revendre plus cher en France

B: Compromettre un paquet ou un fournisseur pour atteindre un projet qui en dépend

C: l'attaque d'un bateau cargo pour augmenter les prix de l'essence

D: quand le livreur indique « remis en main propre » alors qu'il l'a juste gardé pour lui

Que fait npm lorsque il place les dépendances de mon projet dans le dossier node_modules ?

A: du looksmaxxing

B: du curling

C: du hoisting

D: du batch cooking

Que fait npm lorsque il place les dépendances de mon projet dans le dossier node_modules ?

A: du looksmaxxing

B: du curling

C: du hoisting

D: du batch cooking

Que peut faire un script postinstall ?

A: aider mon projet à s'installer 3 fois plus vite

B: appeler ma mère et lui demander de ses nouvelles

C: Déployer une stack Cloudformation sur AWS

D: exécuter du code avec les droits de l'utilisateur courant

Que peut faire un script postinstall ?

A: aider mon projet à s'installer 3 fois plus vite

B: appeler ma mère et lui demander de ses nouvelles

C: Déployer une stack Cloudformation sur AWS

D: exécuter du code avec les droits de l'utilisateur courant

Que ce qui me permet de réaliser une installation prédictible de mon projet ?

A: le lockfile

B: le loch ness

C: la fiesta loca

D: la location saisonnière

Que ce qui me permet de réaliser une installation prédictible de mon projet ?

A: le lockfile

B: le loch ness

C: la fiesta loca

D: la location saisonnière

Que vais-je faire dès lundi matin ?

A: embrasser ma moitié et mes enfants, et leur dire que je les aime

B: me faire une grande tasse de café et remettre en question ma vie

C: faire semblant d'être très occupé alors que Claude fait tout à ma place

D: me renseigner auprès de mon équipe sur notre version de npm et mettre en place des sécurités sur mon projet web

Que vais-je faire dès lundi matin ?

A: embrasser ma moitié et mes enfants, et leur dire que je les aime

B: me faire une grande tasse de café et remettre en question ma vie

C: faire semblant d'être très occupé alors que Claude fait tout à ma place

D: me renseigner auprès de mon équipe sur notre version de npm et mettre en place des sécurités sur mon projet web








merci







openfeedback



SOURCES

Attaque de la supply chain : *le ver « Shai-Hulud » frappe l'écosystème npm*

https://unit42.paloaltonetworks.com/fr/npm-supply-chain-attack

pnpm face à Shai-Hulud : repenser la sécurité des dépendances applicatives

https://www.sqli.com/fr-fr/insights/pnpm-securite-dependances-npm-supply-chain

pnpm : *Fast, disk space efficient package manager*

https://pnpm.io/

Illustrations : *Google Gemini* (Nano Banana v2)

https://gemini.google.com